

Data Retention Policy

Secure Castle, Co.



CONFIDENTIAL | FOR INTERNAL USE ONLY

This document is issued at the direction of outside legal counsel, Merlin & Associates, and is protected by attorney-client privilege. This document is for authorized Secure Castle, Co. personnel only. Unauthorized review, retransmission, or dissemination is prohibited.

Table of Contents

Section 1: Overview..... 3

Section 2: Policy Summary 3

Section 3: Policy Details 4

 RET1000 - PII 4

 RET1001 - Financial 5

 RET1002 - Health 6

 RET1003 - Operational 7

 RET1004 - Security..... 8

 RET1005 - Compliance..... 9

 RET1006 - Knowledge..... 10

Section 4: Legal Hold Procedure 11

Section 5: Revision History 12

Section 1: Overview

This document defines the data retention policies of Secure Castle, Co. for each recognized data type. It establishes how long each category of data must be retained, the regulatory or internal basis for that period, the required disposal method upon expiration, and the procedure for legal hold overrides. All employees and departments are expected to adhere to these policies.

This policy is maintained by the Governance Department and reviewed by outside legal counsel, Merlin & Associates (hereinafter "outside legal counsel" or "outside counsel"). Questions regarding these policies should be directed to the Governance Director.

Section 2: Policy Summary

Policy ID	Data Type	Classification	Retention Period	Regulatory Basis	Legal Hold Required
RET1000	PII	Confidential	5 Years	GDPR	Yes
RET1001	Financial	Restricted	7 Years	SOX	Yes
RET1002	Health	Restricted	6 Years	HIPAA	Yes
RET1003	Operational	Internal	3 Years	Internal Policy	No
RET1004	Security	Restricted	2 Years	NIST	Yes
RET1005	Compliance	Restricted	7 Years	SOX	Yes
RET1006	Knowledge	Internal	10 Years	Internal Policy	No

Section 3: Policy Details

RET1000 - PII

Policy ID	Data Type	Classification	Retention Period	Regulatory Basis	Legal Hold Required
RET1000	PII	Confidential	5 Years	GDPR	Yes

Purpose

Governs the retention of Personally Identifiable Information (PII) collected or processed by Secure Castle, Co. This policy ensures that personal data is not retained longer than necessary while meeting applicable regulatory requirements.

What Qualifies as This Data Type

Any data that can directly or indirectly identify a natural person, including but not limited to: full name, email address, phone number, username, employee ID, home address, date of birth, national identification numbers, or any combination of attributes that together identify an individual.

Retention Period & Reasoning

PII is retained for 5 years from the date of collection or last activity. This period accounts for the statute of limitations on common employment and privacy-related claims and aligns with GDPR Article 5(1)(e) storage limitation principles.

Disposal Method

Upon expiration of the retention period, PII must be securely deleted from all systems, including backups. Electronic records must be permanently erased using data sanitization standards. Physical records must be shredded. Disposal must be documented.

Legal Hold Override

If a litigation hold is active on a data asset containing PII, normal retention and deletion schedules are suspended for the duration of the hold, regardless of the retention period. The hold is initiated at the direction of outside legal counsel and administered by the Governance Manager.

Responsible Party

Governance Director is accountable for policy changes, legal alignment, and compliance. Governance Manager is responsible for day-to-day administration, policy enforcement, and coordination with IT. IT Department is responsible for technical execution of deletions and hold enforcement.

Linked Data Assets

DAT1002, DAT1008

RET1001 - Financial

Policy ID	Data Type	Classification	Retention Period	Regulatory Basis	Legal Hold Required
RET1001	Financial	Restricted	7 Years	SOX	Yes

Purpose

Governs the retention of financial records and transactional data at Secure Castle, Co. Ensures compliance with financial reporting and audit requirements under the Sarbanes-Oxley Act (SOX).

What Qualifies as This Data Type

Any data related to financial transactions, accounting records, invoices, payroll, budget reports, expense reports, tax filings, contracts with financial terms, or audit trails related to financial activity.

Retention Period & Reasoning

Financial records are retained for 7 years in alignment with SOX Section 802, which mandates preservation of audit-related records. This period also satisfies IRS and general accounting standards for record retention.

Disposal Method

Upon expiration, financial records must be securely deleted or physically destroyed. Electronic records must be permanently erased. Disposal must be logged and approved by the Governance Manager prior to execution.

Legal Hold Override

Litigation or regulatory investigation holds suspend all scheduled deletions for affected financial records. Holds are issued at the direction of outside legal counsel and administered by the Governance Manager.

Responsible Party

Finance Department for record ownership. Governance Department for policy compliance. IT Department for technical execution.

Linked Data Assets

DAT1000, DAT1005

RET1002 - Health

Policy ID	Data Type	Classification	Retention Period	Regulatory Basis	Legal Hold Required
RET1002	Health	Restricted	6 Years	HIPAA	Yes

Purpose

Governs the retention of health-related information processed or stored by Secure Castle, Co. Ensures compliance with the Health Insurance Portability and Accountability Act (HIPAA) and protects the privacy of employee health data.

What Qualifies as This Data Type

Any data relating to an individual's physical or mental health condition, medical history, health insurance information, or healthcare provider details. Includes benefits enrollment records, medical leave documentation, and accommodation requests.

Retention Period & Reasoning

Health records are retained for 6 years from the date of creation or last effective date, consistent with HIPAA's minimum necessary standard and record retention requirements under 45 CFR §164.530(j).

Disposal Method

Health records must be securely destroyed upon expiration. Electronic records are permanently erased; physical records are shredded. Given the sensitivity of this data type, disposal requires dual sign-off from the Governance Manager and HR.

Legal Hold Override

Active litigation holds suspend all scheduled deletions for affected health records. Holds are issued at the direction of outside legal counsel and administered by the Governance Manager.

Responsible Party

HR Department for record ownership. Governance Department for policy compliance and disposal approval. IT Department for technical execution.

Linked Data Assets

DAT1001

RET1003 - Operational

Policy ID	Data Type	Classification	Retention Period	Regulatory Basis	Legal Hold Required
RET1003	Operational	Internal	3 Years	Internal Policy	No

Purpose

Governs the retention of operational records generated through the day-to-day activities of Secure Castle, Co. Ensures that internal processes are documented and traceable for a reasonable period without unnecessary data accumulation.

What Qualifies as This Data Type

Records related to internal operations, including process documentation, meeting notes, project records, standard operating procedures, vendor communications, IT service records, and non-financial operational logs.

Retention Period & Reasoning

Operational records are retained for 3 years under internal policy. This period supports internal review cycles, operational continuity, and post-incident analysis without creating excessive storage obligations.

Disposal Method

Upon expiration, operational records are deleted from active systems. Backup copies are purged in alignment with the IT backup retention schedule. Disposal does not require formal documentation unless the record is linked to an open risk or incident.

Legal Hold Override

If an operational record becomes relevant to litigation or a regulatory inquiry, a hold may be applied at the direction of outside legal counsel. The Governance Manager is responsible for notifying relevant teams.

Responsible Party

Department heads are responsible for maintaining records within their function. Governance Department oversees policy compliance. IT Department manages technical storage and deletion.

Linked Data Assets

DAT1003, DAT1007

RET1004 - Security

Policy ID	Data Type	Classification	Retention Period	Regulatory Basis	Legal Hold Required
RET1004	Security	Restricted	2 Years	NIST	Yes

Purpose

Governs the retention of security-related records at Secure Castle, Co., including access logs, incident reports, vulnerability assessments, and audit trails. Supports ongoing security monitoring, incident response, and compliance with NIST cybersecurity framework guidelines.

What Qualifies as This Data Type

Security logs, access control records, authentication events, device event records, intrusion detection alerts, vulnerability scan results, penetration test reports, incident response records, and any data generated by security monitoring tools.

Retention Period & Reasoning

Security records are retained for 2 years, consistent with NIST SP 800-92 guidelines for log management and the operational window within which security events are most likely to require review or legal relevance.

Disposal Method

Security records are securely deleted upon expiration. Given their sensitivity, electronic deletion must follow data sanitization standards. Disposal is coordinated between the Governance and IT departments and must be logged.

Legal Hold Override

Security records involved in active incidents, litigation, or regulatory investigations are subject to legal hold and must not be deleted until the hold is formally lifted by outside legal counsel.

Responsible Party

Governance and Security Department for record ownership and compliance. IT Department for technical log management and deletion execution.

Linked Data Assets

DAT1006, DAT1011

RET1005 - Compliance

Policy ID	Data Type	Classification	Retention Period	Regulatory Basis	Legal Hold Required
RET1005	Compliance	Restricted	7 Years	SOX	Yes

Purpose

Governs the retention of compliance-related records at Secure Castle, Co., including policy acknowledgments, audit findings, regulatory filings, and evidence of control testing. Ensures that Secure Castle can demonstrate adherence to applicable laws and regulations.

What Qualifies as This Data Type

Policy acknowledgment records, compliance audit reports, control testing evidence, regulatory correspondence, training completion records, risk assessments, and any documentation generated to demonstrate regulatory compliance.

Retention Period & Reasoning

Compliance records are retained for 7 years, consistent with SOX requirements and general best practice for compliance documentation. This period ensures records are available for regulatory audits and legal proceedings within applicable statutes of limitations.

Disposal Method

Compliance records are securely deleted upon expiration following formal review and approval by the Governance Manager. Disposal is logged and retained as evidence of compliant record management.

Legal Hold Override

Any compliance record relevant to active litigation or a regulatory investigation is subject to legal hold. Holds are issued at the direction of outside legal counsel and take precedence over scheduled deletion.

Responsible Party

Governance Department owns and administers compliance records. IT Department manages storage and technical deletion.

Linked Data Assets

None currently linked

RET1006 - Knowledge

Policy ID	Data Type	Classification	Retention Period	Regulatory Basis	Legal Hold Required
RET1006	Knowledge	Internal	10 Years	Internal Policy	No

Purpose

Governs the retention of institutional knowledge assets at Secure Castle, Co., including internal documentation, training materials, process guides, and knowledge base articles. Ensures continuity of organizational knowledge over time.

What Qualifies as This Data Type

Internal wikis, training materials, onboarding documentation, standard operating procedures, knowledge base articles, lessons learned records, policy drafts, and any documentation intended to preserve institutional knowledge rather than transactional data.

Retention Period & Reasoning

Knowledge assets are retained for 10 years under internal policy, reflecting their long-term organizational value. Unlike transactional records, knowledge assets support continuity across employee turnover and organizational change.

Disposal Method

Knowledge assets are reviewed at the end of their retention period by the owning department. Records that remain relevant may be renewed; those that are outdated or superseded are deleted from active systems and purged from backups.

Legal Hold Override

Knowledge assets are not subject to routine legal hold requirements. However, if a specific document becomes relevant to litigation, a targeted hold may be applied at the direction of outside legal counsel.

Responsible Party

Department heads are responsible for maintaining and reviewing their knowledge assets. Governance Department oversees policy compliance.

Linked Data Assets

DAT1004, DAT1010

Section 4: Legal Hold Procedure

A legal hold suspends the normal retention and disposal schedule for any data asset that may be relevant to pending, threatened, or anticipated litigation or regulatory investigation. The following process applies:

- Legal holds are initiated at the direction of outside legal counsel and communicated by the Governance Manager.
- Upon notification, affected employees must immediately suspend deletion, overwriting, or archiving of relevant data assets.
- IT is responsible for implementing technical holds on server-side data and backups.
- Employees are responsible for preserving any data under their direct control.
- Legal holds remain in effect until formally lifted in writing by the Governance Manager.
- All holds and their associated data assets are tracked in the `data_assets` table via the `active_legal_hold`, `legal_hold_start_date`, and `legal_hold_reason` fields.

Section 5: Revision History

Version	Date	Author	Approved By	Summary of Changes
1.0	05/29/2026	Kristoff Ice, Governance Manager	Mary Poppins, Governance Director	Initial release. Defined retention policies for data types. Established retention periods, regulatory basis, disposal procedures, legal hold override process, and responsible parties.